

Rapport de Synthèse : Audit et Architecture de Détection

Projet : SAE 5 Cyber & DevCloud - "Nixie" | Maxine Botturi & Sirine Ben Kadhi

Date : Janvier 2026

Destinataires : Direction Technique / Client

1. Résumé Exécutif

Dans le cadre de la sécurisation d'un environnement Active Directory sensible, notre équipe a déployé et comparé plusieurs solutions de surveillance et de détection (basé sur l'infrastructure *Game of Active Directory*). Ce "Proof of Concept" (PoC) visait à déterminer la stack défensive la plus efficace, la plus simple à déployer et offrant la meilleure visibilité sur les menaces.

Notre conclusion est sans appel : bien que la stack Elastic offre une puissance d'analyse brute considérable, **la solution Wazuh, couplée à l'IDS Suricata, représente le meilleur compromis efficacité/maintenabilité pour votre environnement.**

2. Architecture Mise en Œuvre

Pour garantir une objectivité totale, nous avons déployé deux chaînes de détection parallèles sur l'infrastructure ESSOS.LOCAL et SEVENTHKINGDOM.LOCAL :

1. Collecte de Logs Centralisée (OpenWEC) :

- Mise en place de **deux serveurs OpenWEC conteneurisés** (Docker), isolant la collecte de logs par domaine pour plus de sécurité et de performance.
- Déploiement de **Sysmon** et configuration de l'audit Windows via GPO pour une remontée automatique et granulaire des événements.

2. Analyse et Détection (SIEM & IDS) :

- **Stack A** : Serveur **Elastic** (ELK) avec agents déployés via Ansible.
- **Stack B** : Serveur **Wazuh** avec agents déployés via Ansible.
- **Surveillance Réseau** : Sonde IDS **Suricata** positionnée en amont pour l'analyse des flux réseaux.

3. Innovation & Visualisation :

- Développement d'outils Python intégrant des **fonctionnalités LLM** (IA) pour l'analyse sémantique des logs OpenWEC.
- Création d'un **Dashboard Streamlit** pour une visualisation synthétique des métriques de sécurité.

3. Validation Offensive : Scénarios d'Attaque

Pour éprouver la robustesse de ces solutions en conditions réelles, nous avons exécuté deux campagnes d'attaques distinctes sur le domaine ESSOS.LOCAL. Ces scénarios nous ont permis de mesurer la réactivité de chaque outil :

- **Scénario 1 (Faible Intensité)** : Simulation d'une phase de reconnaissance (scan de ports) et tentatives d'accès initiales (brute-force SMB). *Objectif* : Tester les seuils de détection de base.
- **Scénario 2 (Haute Intensité)** : Simulation d'une compromission avancée incluant l'exploitation

de vulnérabilités (ZeroLogon), et la connexion distante (SMB). *Objectif : Valider la capacité de corrélation d'événements critiques.*

4. Comparatif des Solutions (SIEM)

Suite à l'analyse des logs générés par ces attaques, voici notre comparatif :

Critère	Wazuh (Recommandé)	Elastic (ELK)
Déploiement	Rapide : L'automatisation Ansible a permis un déploiement des agents quasi-instantané et sans friction.	Complexe : La configuration nécessite plus de finesse et de ressources serveur.
Détection	Native : Les règles par défaut (SCA, Rootcheck) et la corrélation d'événements sont immédiatement opérationnelles.	À construire : Demande un effort important de création de règles et de tuning pour atteindre le même niveau d'alerte.
Lisibilité	Excellente : Les alertes sont claires, catégorisées et directement exploitables pour la réponse à incident.	Densité : Très puissant pour la recherche (Threat Hunting) mais peut noyer l'analyste sous le volume de données brutes.
Réponse	Intègre nativement l' Active Response pour bloquer les menaces automatiquement.	Nécessite des intégrations tierces pour l'automatisation de la réponse.

Verdict : Wazuh s'impose par sa capacité à fournir de la valeur immédiatement ("Out of the box") tout en restant flexible.

5. La Nécessité de l'IDS Suricata

La question "Dois-je mettre un système IDS en place ?" reçoit une réponse positive ferme.

- **Complémentarité** : Alors que Sysmon/Wazuh voient ce qui se passe *sur* la machine (processus, fichiers), Suricata voit ce qui transite *entre* les machines.
- **Preuve par l'exemple** : Lors de nos tests d'intrusion (notamment sur les mouvements latéraux), Suricata a levé des alertes sur des signatures de trafic malveillant que les logs systèmes seuls n'auraient pas permis de qualifier avec certitude.
- **Visibilité** : Il est le seul rempart capable de détecter des tentatives d'exploitation réseau avant même qu'elles n'atteignent leur cible.

6. Recommandations

1. **Adopter le couple Wazuh + Suricata** comme socle de votre SOC (Security Operations Center).
2. **Maintenir l'architecture OpenWEC** : Elle découple la collecte de l'analyse, permettant de changer de SIEM à l'avenir sans reconfigurer tous les postes clients.
3. **Industrialiser les Scripts IA** : Nos prototypes de traitement de logs par LLM ont montré un potentiel fort pour réduire la fatigue des analystes en pré-qualifiant les incidents.